STRIDE Threat Model

Group 03 | M1 design | Planned checks, not executed attacks

Method and assets

STRIDE: Spoofing identity, Tampering data, Repudiation of actions, Information disclosure, Denial of service and Elevation of privilege. Likelihood (L) and impact (I) are qualitative Low/Medium/High ratings for the baseline or pre-control state, not measured probabilities. Controls reduce risk but do not prove implementation. Assets: offline Root/Issuing keys, gateway identity and tunnel policy, portal/staff identity, KDC keys/tickets, evidence and repository integrity. Authorized attacker is WAN-only at 172.16.3.66; tests remain inside this lab.

Lab-specific threat register

ID / component / STRIDE	Scenario and L / I	Control and planned verification
S01 / WAN HTTP / Information disclosure	Attacker observes client-br HTTP body across gateway WAN before VPN. L High / I High.	M1 documents real known plaintext baseline; later ESP plus TLS. Compare M1 vs T7 PCAP with same marker; absent marker alone is not proof without successful client response.
S02 / portal DNS + TLS / Spoofing	Lab name override sends portal client to attacker presenting rogue-CA leaf. L High / I High.	Root trust + SAN validation; never curl -k in final tests. T5 refusal; isolated insecure comparison only in attacks/. No real OS/browser trust change.
S03 / gateway IKE_AUTH / Spoofing	Attacker uses valid staff clientAuth certificate as gw-branch or a rogue gateway chain. L Medium / I High.	Pin exact peer SAN identity, trusted chain, gateway purpose and CRL. T8 fails for both cases with strongSwan logs; test same-CA wrong identity explicitly.
S04 / staff CRL / Elevation of privilege	Revoked staff03 authenticates because nginx worker uses stale CRL or resumed TLS session. L Medium / I High.	Monitor nextUpdate, atomic PEM deployment/reload, fail on unknown status, expire resumptions/connections. T4 plus expired/missing CRL and reconnect tests.
S05 / offline Root key / Tampering	Root key accidentally enters /work mount; compromised service can sign an alternative Issuing CA. L Medium / I High.	Root outside repo/build context/mounts, encrypted offline, mode 600, restricted backup. Inspect mounts/storage, full-history scan T13, certificate-chain/pathlen tests.
S06 / AP authenticator / Spoofing	Attacker replays captured valid service login to repeat an action. L High / I High.	AEAD, ticket identity binding, +/-60 s window, atomic replay cache and one-time nS confirmation. T12a weak success; T12b fixed refusal, concurrent duplicate and restart tests.
S07 / tickets + routing / Tampering	Attacker changes service ID, ticket expiry or AAD fields, or swaps a TGT for a service ticket. L Medium / I High.	Domain-separated AEAD keys/AAD, canonical encoding, destination/type validation. Modified-byte and cross-role ticket negative tests in T11/T12b.

ID / component / STRIDE	Scenario and L / I	Control and planned verification
S08 / gateway forwarding / Information disclosure	IKE daemon stops and Linux routes campus traffic in clear. L High / I High.	Final IPsec-policy-required firewall; no blanket established rule bypass for protected selectors. T9 daemon stop while client sends known body; WAN capture must show no clear packet. M1 exception explicitly retired in M3.
S09 / TLS + IKE negotiation / Tampering	Misconfigured peer forces obsolete TLS, non-AEAD/non-PFS suites or weak IKE proposal. L Medium / I High.	Explicit version/proposal allowlist and PFS. T6 and SR13 weak IKE offer refusal; testssl no HIGH/CRITICAL.
S10 / KDC AS + replay cache / Denial of service	Forged AS traffic exhausts password KDF/AEAD CPU or cache; clock jump invalidates all tickets. L High / I Medium.	Bounded message sizes/rate limits, verify before cache insertion, retain live replay entries, trusted clock/skew, capacity fail-closed. Load, malformed-frame and time-jump tests in isolated lab.
S11 / test logs + Git / Repudiation	Claimed PASS or teammate contribution has no dated command/output or traceable commit. L Medium / I Medium.	Record actual tester, expected/actual, UTC time and artifact hash; reviewed commits, no invented attribution. Inspect unified log and contribution record; T13.
S12 / /staff/ access boundary / Elevation of privilege	Anonymous caller bypasses staff check using /staff, encoded path or forged identity header. L Medium / I High.	Cover normalized /staff and subtree, require verified cert, escape display identity, distrust HTTP headers. T3/T4 path matrix with no certificate and revoked certificate.
S13 / .env / keys / Information disclosure	First commit or later tag exposes private key, PSK, p12 or TLS session key log in Git history. L Medium / I High.	.gitignore before staging, review tracked paths and full-history content scan before every milestone. T13; if leak occurs rotate credentials and repair history before any release.
S14 / Docker host boundary / Elevation of privilege	Overbroad host networking, Docker socket or privileged container enables experiments outside lab. L Medium / I High.	Three internal non-masqueraded networks, no ports/host network/socket/privileged mode; explicit capabilities for network setup/capture and process/file ownership. Inspect Compose caps/network options and no default routes. Host admin remains trusted.

Residual risk and priorities

Highest priorities before runtime acceptance: actual isolation/routes, genuine WAN plaintext capture, role-restricted secret placement and resolving replacement-kit acceptance. Baseline has no cryptographic source authentication and remains intentionally observable. Future TLS does not hide metadata; VPN does not protect LAN plaintext; CRL distribution can be blocked; password-based preauthentication can leak an offline guessing oracle. The custom protocol is educational and needs adversarial review; do not present draft design as production assurance.